

SIMA_ROADMAP

Backend developer için uygulama rehberi. Bu doküman: ne yapacaksın, hangi sırayla, hangi API'leri çağıracağını / yazacağını.

Kaynaklar: CarCat × M10 Integration Brief (Desktop HTML); AzInTelecom SIMA KYC Documentation (17.03.2026).

ONEMLI: v1'de tek SIMA endpoint kullanılacak: Verify Citizen Identity. Global Identification / passport / foreign v1 kapsamında DEĞİL.

1. Ne yapıyoruz? (1 cümle)

CarCat kullanıcısı uygulamada FIN + vesika no (veya doğum tarihi) + canlı selfie verir; backend bunu SIMA'ya gönderir; SIMA yuzu devlet kaydıyla eşleştirirse hesabına doğrulanmış FIN bağlanır. Selfie saklanmaz — sadece sonuç metadata saklanır.

FIN = SIMA body'deki pin alanı (7 karakterlik şahsi kimlik numarası).

2. SIMA ile IDDA'yi karıştırma

- SIMA = yazma tarafı. Gerçek kullanıcı + kamera. Kimlik doğrulama. BU ROADMAP.
- IDDA = okuma tarafı. M10 bilinmeyen FIN gönderince araç listesi çözümleme. SIMA bittikten SONRA ayrı iş.

Burada API yazma.

M10 Path A (tanımlı FIN → history) SIMA doğrulamasına bağlı. M10 Path B (IDDA) bu PDF'in sonunda kısaca not; v1 bloklamaz.

3. Sırayla ne yapacaksın

Aşağıdaki adımları sırayla uygula. Bir önceki bitmeden sonrakine geçme (özellikle credentials ve legal).

ADIM 0 — Başlamadan önce alınan gerekenler

- SIMA Identifier (partner id)
- SIMA HMAC secret key
- Staging base URL (sonra prod URL)
- Threshold: liveness 0.9, similarity 0.9 (SIMA tarafında partner config)
- Legal/Security: Frankfurt'ta FIN metadata OK; selfie saklanmayacak
- Product kuralı: 1 FIN ↔ 1 hesap (default: başka hesapta varsa BLOK)

Bunlar yoksa kod yazma. Env örnekleri: SIMA_BASE_URL, SIMA_IDENTIFIER, SIMA_HMAC_KEY, SIMA_AUTH_SCHEME=HMACSHA256

ADIM 1 — Veritabanına alan ekle (User / Account)

Selfie / livePhoto ASLA saklanmaz. Sadece doğrulama sonucu:

- fin (string) — doğrulanan FIN / pin
- finVerified (boolean) — true sadece başarılı gate sonrası
- finVerifiedAt (timestamp)
- simaTransactionId (string)
- livenessScore, similarityScore (decimal)
- livenessThreshold, similarityThreshold (kullanılan eşik, örnek 0.9)
- documentNumber (opsiyonel metadata) — doğrulama anında kullanılan

Constraint: finVerified=true olan fin UNIQUE olmalı. Aynı FIN başka doğrulanmış hesapta varsa verify API 409 / iş kuralı hatası dönsün.

FIN M10 lookup için aranabilir olmalı ama PII. Security karar vermeli: column encrypt veya hash+lookup. Backend simdilik alanları ekler; şifreleme stratejisini security imzalat.

ADIM 2 — SIMA HTTP client yaz (sadece server-side)

Flutter HMAC key GORMEZ. Mobile selfie + FIN toplar, bizim backend'e gönderir; bizim backend SIMA'yi çağırır.

Dis API (SIMA — sen cagiracaksin)

POST {SIMA_BASE_URL}/api/v1/kyc/identity/verify

Header'lar

Content-Type: application/json
 Auth-Scheme: HMACSHA256
 Signature: <minified body'nin Base64 HMAC'i>
 Identifier: <partner id>
 DeviceInfo: (opsiyonel)

Body

```
{
  "pin": "10AAABC",
  "documentNumber": "AA0012345",
  "birthDate": null,
  "livePhoto": "<base64 jpeg>",
  "idempotencyKey": "<yeni UUID her istekte>"
}
```

- pin = FIN (zorunlu)
- livePhoto = base64 (zorunlu)
- idempotencyKey = her request icin yeni UUID; body icinde, header degil
- documentNumber VEYA birthDate — tam biri dolu, digeri null. Ikisi birden veya ikisi bos = SIMA 713 / 714
- Yeni nesil vesika: documentNumber AA veya AB ile baslar. Eski nesil: AZE prefix'ini SIL (ornegin AZE123 → 123 seklinde doc'a gore strip)

HMAC imzalama — HyperService ile ayni tuzak

Sirayla:

- 1) Body Map/DTO olustur (idempotencyKey dahil)
- 2) JSON'u BIR KEZ minify et (bosluk yok): ObjectMapper yazarken pretty print KAPALI
- 3) Ayni minified string'i hem HMAC'le hem HTTP body olarak gonder
- 4) HMAC-SHA256(key, minifiedBytes) → Base64 → Signature header

Imzaladigin baytlar ≠ gonderdigin baytlar ise 70001 / imza hatasi alirsin. String'i bir kez uret, iki yerde kullan.**Basarili sayma kurali (KRITIK)**

isSuccess=true tek basina DOGRULAMA DEGIL. Sadece teknik islem bitti demek.

```
verified = isSuccess == true
  && result.livenessStatus == true
  && result.similarityStatus == true
```

verified=false ama isSuccess=true olabilir (dusuk skor). Bunu kullaniciya 'dogrulama basarisiz' diye goster; 5xx yapma.

Nadir: skor threshold ustunde olsa bile livenessStatus=false gelebilir (ek biometric check). Yine failed verification.

ADIM 3 — Bizim backend API'lerini yaz (mobile bunlari cagirir)

Asagidaki endpoint'ler CarCat backend'inde senin yazacagin API'ler. Isimler ornek; path convention projedeki auth/API stiline uyarlabilir.

API-1: KYC dogrulama

POST /api/v1/kyc/sima/verify
 Auth: Bearer (login veya register-token JWT)

Request (mobile → backend):

```
{
  "fin": "10AAABC",
  "documentNumber": "AA0012345", // veya null
  "birthDate": null, // veya "1990-01-25"
  "livePhotoBase64": "..."
}
```

Backend icinde sirayla yap:

- 1) JWT'den userId al; user yoksa 401
- 2) fin / livePhoto validate (bos degil, FIN format)
- 3) documentNumber XOR birthDate kontrolu
- 4) Ayni FIN baska verified hesapta var mi? Varsa 409 COLLISION — dur
- 5) User zaten finVerified ise: product karari (idempotent 200 veya 409)
- 6) UUID idempotencyKey uret
- 7) SIMA client ile Verify Citizen cagir
- 8) SIMA error → asagidaki mapping ile HTTP + code don; DB'ye verified yazma
- 9) verified gate true ise: fin + metadata kaydet, finVerified=true; selfie'yi AT
- 10) Response don (asagida)

Success response ornek:

```
{
  "verified": true,
  "fin": "10AAABC",
  "name": "ARAZ",
  "surname": "ELIYEV",
  "livenessScore": 0.99,
  "similarityScore": 0.99,
  "transactionId": "100550"
}
```

Fail response ornek (business):

```
{
  "verified": false,
  "code": "SIMA_752",
  "message": "Yuz eslesmedi. Tekrar deneyin."
}
```

API-2: KYC status

GET /api/v1/kyc/status

Auth: Bearer

```
{
  "finVerified": true,
  "fin": "10AAABC", // maskelenebilir: 10***BC
  "finVerifiedAt": "2026-08-05T10:00:00Z"
}
```

Mobile UI bu endpoint ile 'dogrulanmis / degil' gosterir. Dogrulama karari asla client-side 'SIMA success' ile verilmez — sadece bizim flag.

ADIM 4 — Uctan uca akis (sirayla)

1. User login/register (mevcut telefon akisi bozulmaz)
2. Flutter: FIN + vesika/dogum + selfie (foto kurallarina uy)
3. Flutter → POST /api/v1/kyc/sima/verify (Bearer)
4. Backend → minify + HMAC → POST SIMA .../identity/verify
5. Backend gate: isSuccess && livenessStatus && similarityStatus
6. OK ise DB update; selfie discard
7. Flutter → GET /api/v1/kyc/status (ekran guncelle)
8. (Sonra) M10 Path A bu finVerified FIN uzerinden history okuyacak

ADIM 5 — SIMA hata kodlarini map et

SIMA error.errorCode gelir. Kullaniciya Turkce/Azerice mesaj; 710/750 gibi sistem hatalarini support log'a yaz, generic mesaj goster.

```
722 / 7072 → kayit bulunamadi, tekrar dene
721 / 7071 → vesikada foto yok, dogrulama yapilamaz
751      → liveness fail → yeni selfie (isik/mesafe)
752      → similarity fail → bir retry hakki
7530     → birden fazla yuz → tek yuz iste
7080-7082 → foto/base64 sorunlu → yeniden cek
```

713 / 714 → documentNumber / birthDate kuralı
70002 → validation — bizim request'i kontrol et
710 → credential/config — kullaniciya gosterme, alert
750 → biometric servis — backoff retry + log
70000/716 → unexpected — log + generic

ADIM 6 — Ops / guvenlik (kodla birlikte)

- Rate limit: verify endpoint (brute FIN + selfie abuse)
- Log: pin/fin maskele; livePhoto ASLA loglama; transactionId + errorCode logla
- Feature flag: sima.kyc.enabled — staging ac, prod kontrollu
- Timeout / retry: 750 icin sinirli retry; 752'de otomatik spam etme
- HMAC key sadece env/secret store; repo'ya koyma

4. Flutter tarafi (backend'in bilmesi gereken)

Sen yazmazsin ama dogrulama fail rate'i buradan gelir. Capture kurallari:

- Yuz kadrajın %70–80'i; tek yuz; JPEG; 640x480 – 1080x1920; ≤1 MB
- Face box genisligi > 200px; kafa ±20°; notr ifade; gozler acik
- Filtre/crop yok — sadece downscale izinli

Mobile sadece bizim API'leri cagirir; SIMA URL ve key mobile'da olmaz.

5. Sonra (SIMA v1 bittikten sonra) — M10 / IDDA

Bu kisim ayri epic. SIMA v1'i bekletme.

- Path A: M10 FIN gonderir → CarCat'ta verified FIN varsa bagli arac + maintenance history don (SIMA/selfie yok).
- Path B: FIN bilinmiyorsa → CarCat IDDA'dan sahip olunan araclar → kullanıcı secer → history veya 200 + maintenanceHistory: []

Bos history = 404 DEGİL, 200 + bos array.

6. Bitmis sayilir (Definition of Done)

- Staging'de gercek SIMA credentials ile verify calisiyor
- POST /kyc/sima/verify + GET /kyc/status canli
- Gate dogru: uc bayrak birden true olmadan finVerified yazilmiyor
- Selfie DB/disk/S3'te yok
- FIN collision bloklaniyor
- SIMA hata kodlari kullanıcı mesajina map
- HMAC minify tek string ile imza + body ayni

Yeniden uretmek icin: `python docs/generate_sima_roadmap_pdf.py`

Cikti: `docs/SIMA_ROADMAP.pdf`